

RISK MANAGEMENT & ANALYSIS

LECTURE 16

Nusrat Jahan Tazin (NJN)

Lecturer

Department of Software Engineering

Daffodil International University



RISK?

What can go wrong?
What is the likelihood?
What will be the damage?
What can be done about it?

Risk analysis and management are a set of activities that help a software team to understand and manage uncertainty about a project.



Key Categories of Risk

Category	Description	Example from the Delivery App Scenario
Technical	Problems with design, implementation, testing, or maintenance.	Risk: Incorrect calculation logic (producing "unexpected results").
External Dependency	Reliance on components/services outside the team's direct control.	Risk: Map API slowness or failure (causing the "system fails" observation).
Financial/Business	Cost overruns, loss of revenue, or market changes.	Risk: Loss of revenue due to inaccurate delivery fees.
Schedule/Time	Delays in delivery or critical path tasks.	Risk: Integration issues require rework, delaying the launch.

Common Categories of Risk

Common Risk Categories

1. Technical Risks: Issues with technology, integration, performance, security, or quality.
Examples: New unproven tech, complex interfaces, security vulnerabilities, undetected bugs.
1. Project Management Risks: Failures in planning, execution, or control.
Examples: Poor estimation, budget overruns, missed deadlines, scope creep, inadequate testing.
1. People/Human Resource Risks: Problems related to the development team or stakeholders.
Examples: Lack of skilled talent, poor communication, team member absence, low commitment, stakeholder conflicts.
1. Requirements Risks: Ambiguity or instability in what the software should do.
Examples: Unclear or changing requirements, incomplete functional definitions, user misunderstanding.
1. Organizational/Business Risks: Broader company or market factors.
Examples: Strategic misalignment, market changes, budget cuts, lack of management support, product liability.

RISK CLASSIFICATION

Some of most important risks in software engineering project are categorized as:

1. software requirement risks
2. software cost risks
3. software scheduling risk
4. software quality risks

Risk management life cycle:

- a. Identify(risk identification)
- b. Analyze(risk analysis)
- c. Plan(contingency planning)
- d. Track and Implementation (risk monitoring)
- e. Control(recovery management)



Risk management life cycle

Stage	Action	Short Description
a. Identify	Risk Identification	The process of discovering, recognizing, and describing risks. This involves determining the <i>source</i> of the risk and what could be impacted (e.g., workshops, checklists, brainstorming).
b. Analyze	Risk Analysis	The process of understanding the nature of the risk and determining its likelihood (probability of occurrence) and impact (potential consequence). This allows for prioritizing risks.
c. Plan	Contingency Planning	Developing specific actions, strategies, and resources that will be used <i>if</i> a risk becomes a reality (a "contingency"). This is the proactive 'what if' preparation.
d. Track and Implementation	Risk Monitoring	Systematically keeping track of identified risks, monitoring residual risks, identifying new risks, and ensuring the execution of planned risk responses. It involves watching the risk 'triggers'.
e. Control	Recovery Management	Taking action to handle a risk event that has actually occurred (an 'issue'). This involves executing the contingency plan, taking corrective action, and managing the recovery to minimize the negative effects.

Risk Response Strategy

AVOID

Eliminate cause
of the risk

MITIGATE

reduce impact
of the risk

vibhorchandel.com

ACCEPT

don't do
anything

TRANSFER

have 3rd party take
on the responsibility

The Four Risk Response Strategies

A. Mitigation (Reduce Impact or Probability)

- **Goal:** Make the risk less likely to happen, or less painful if it does.
- **Response for Risk 1 (API Slowdown):**
Implement **Timeouts and Fallbacks**. This doesn't stop the API from being slow (reducing the **probability** is hard), but it *significantly* reduces the **impact** (system no longer crashes, it defaults to a safe state).

B. Avoidance (Eliminate the Risk)

- **Goal:** Change the plan or scope to eliminate the conditions that create the risk.
- **Example:** If using an experimental technology is too risky, **Avoid** the risk by using a proven, stable technology instead.

The Four Risk Response Strategies

C. Acceptance (Acknowledge and Prepare)

- **Goal:** Decide to live with the risk, usually because the cost of mitigation outweighs the potential impact.
 - **Active Acceptance:** Create a **contingency plan** (Plan B) if the risk occurs (e.g., using a manual spreadsheet calculation if the system fails).
 - **Passive Acceptance:** Do nothing and deal with the consequences if it happens.
- **Response for Risk 2 (Calculation Error):** **Acceptance (Active)** by implementing **Monitoring**. Monitor transactions for suspicious fee amounts so you can quickly fix the bug and issue refunds/corrections after the error occurs.

D. Transfer (Shift the Risk to a Third Party)

- **Goal:** Make another party responsible for the risk's impact.
- **Example:** Buying **Insurance** (Transferring financial risk), or signing a **Service Level Agreement (SLA)** with the Map API provider that makes them financially responsible for downtime.